

Integrating DevSecOps and STPA for Healthcare Software under LGPD: A Case Study in the Brazilian Unified Health System

Last update: 06/11/2026

Overview of the semester project

In this semester project, students will apply concepts from DevSecOps, healthcare software engineering, and the System-Theoretic Process Analysis (STPA) technique to analyze a socio-technical software development and delivery process operating under the Brazilian General Data Protection Law (LGPD).

The project investigates how **inadequate controls**, **unsafe interactions**, **configuration flaws**, and **insufficient feedback mechanisms** within DevSecOps pipelines may contribute to **privacy**, **security**, and **safety** violations in healthcare software systems.

To support the development of the work, a partial STPA analysis will be provided to students as the starting point of the project. The main task of each group will be to continue and expand the analysis based on the concepts discussed throughout the course.

This work emphasizes:

- socio-technical systems thinking;
- control and feedback structures;
- unsafe control actions (UCAs);
- causal scenarios;
- privacy, security, and safety constraints;
- DevSecOps verification pipelines;
- LGPD compliance in healthcare software.

Questions:

- vinicius.boiago@sou.unifal-mg.edu.br
- pagliares@bcc.unifal-mg.edu.br

Recommended Initial Activities

Task 1 (Most Important Before Starting the Project)

- Watch the presentation by John Thomas regarding the new Step 4 of STPA:

- [STPA: Formally Developing Loss Scenarios – John Thomas](#)
- Understanding the concepts presented in this video is considered essential before starting the project analysis.

Task 2 (Optional)

- Feel free to use MicroSTAMP during this project (it has reporting capabilities that may be of interest from yours)
- The use of MicroSTAMP in this project assignment is optional and will not directly affect grading. However, the tool may help students organize and visualize their STPA analysis.
- If you want, install MicroSTAMP locally: [MicroSTAMP GitHub Repository](#)

Task 3 (Optional)

- Watch the introductory MicroSTAMP video #1: [MicroSTAMP Introduction #1](#)

Task 4 (Optional)

- Watch the introductory MicroSTAMP video #2: [MicroSTAMP Introduction #2](#)

Task 5 (Optional)

- Watch the introductory MicroSTAMP video #3: [MicroSTAMP Introduction #3](#)

Task 6

Table link: [x Control Actions from the refined structure.xlsx](#)

Based on the provided table containing all the Control Actions (CAs) from the refined control structure (Figure 2), you must fill in your group next to a CA.

NOTE: If a group wishes to analyze more than one CA, they must select a CA that has not yet been chosen by another group. In the event that new groups are formed, those new groups will have priority over existing groups in claiming unassigned CAs.

OPTIONAL: If proposing a new control action that is not on the list, you must submit a new, refined control structure diagram. Along with the diagram, you must explicitly point out: **(i)** The process model variables/values the controller must have to execute this new CA. **(ii)** Any new feedback loops required to support it.

Once your CA(s) are selected, you must systematically evaluate them to perform the Step 3 of STPA deriving Unsafe Control Actions (UCAs) according to the four categories: **(i)** A required control action is not provided; **(ii)** An unsafe control action is provided; **(iii)** A control action is

provided too early, too late, or out of sequence; **(iv)** A control action is applied too long or stopped too soon. This is illustrated in Figure 1. An example of this UCA derivation can be found at the end of this document in **Table 6**.

Still in Step 3, after finding the UCAs, you must derive the corresponding Controller Constraints. A controller constraint specifies the controller behaviors that need to be satisfied in order to prevent the identified UCAs. An example of this controller constraint derivation can be found at the end of this document in **Table 7**.

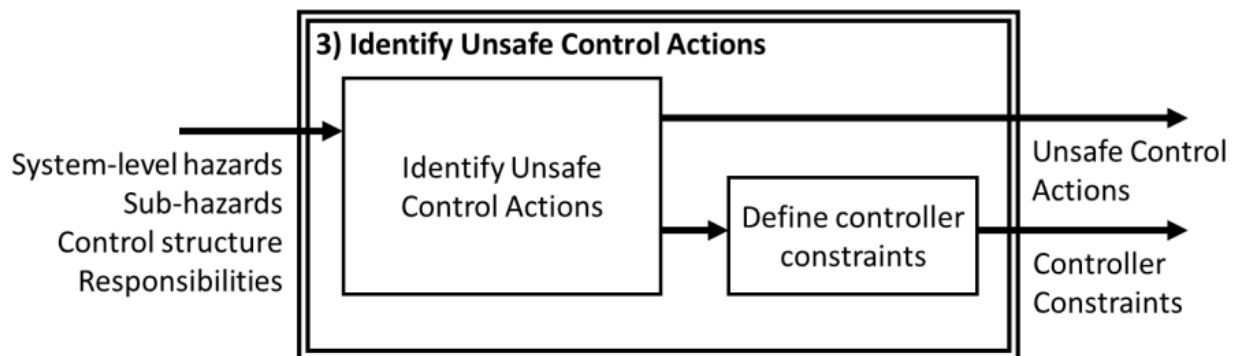


Figure 1. Overview of control action analysis. Source: Leveson and Thomas [1]

Task 7

Applying the concepts from John Thomas's video on the formalization of STPA Step 4 (**Task 1**), the group must now identify loss scenarios that **must not include component failures as a causal factor** and lead the controller to issue the UCAs previously identified in **Task 6**. **IMPORTANT:** The group must deliver at least one loss scenario in which **all involved components behave according to their specifications and no component failure occurs**.

Each loss scenario should be presented in a table containing the following fields:

- (i) Related UCA:** The UCA from Task 6 that this scenario addresses;
- (ii) Controllers Involved:** The controller(s) acting in the scenario;
- (iii) Scenario Archetype:** Identify the scenario archetype class;
- (iv) High-Level Scenario:** Identify the high-level scenario (automatically generated by MicroSTAMP);
- (v) High-level Solution:** High-level solutions aimed at preventing or mitigating the overarching high-level scenario.
- (vi) Refined Scenario:** A step-by-step narrative explaining exactly how and why the scenario unfolds;
- (vii) Causal Factors:** The underlying reasons (e.g., process model flaws, inadequate feedback, sensor delays) that lead to the loss scenario.
- (viii) Refined Solution:** Solutions to directly prevent or mitigate the identified refined scenario.

An example of a loss scenario can be found at the end of this document in **Table 8**.

NOTE: If the group did not find enough UCAs for your chosen CA to cover all team members, the group must return to the provided table, sign up for an additional available CA, and perform **Task 6**

Task 8

- After completing the analysis, the group must propose at least one derived requirement to be implemented in order to mitigate or eliminate the loss scenarios identified in **Task 7**. An example of a derived requirement can be found at the end of this document in **Table 9**.

In what follows, we provide more contextual information about the system being analyzed, before presenting the partial STPA analysis.

Integrating DevSecOps and STPA for Healthcare Software under LGPD: A Case Study in the Brazilian Unified Health System

ABSTRACT

[CONTEXTUALIZATION] The General Data Protection Law (LGPD) regulates personal data processing in Brazil, including health data handled by healthcare software in the Brazilian Unified Health System (SUS). As healthcare software increasingly relies on DevSecOps pipelines, socio-technical interactions and control flaws become relevant concerns for maintaining privacy, security, and safety constraints throughout the software lifecycle. **[PROBLEM]** Although DevSecOps pipelines employ automated verification mechanisms such as Static Application Security Testing (SAST), Software Composition Analysis (SCA), and Infrastructure as Code (IaC) scanning, these mechanisms provide limited support for analyzing inadequate controls and feedback flaws between automated tools and human operators. **[OBJECTIVE]** This work proposes integrating System-Theoretic Process Analysis (STPA) with DevSecOps to analyze control and feedback structures in software development and operation processes. **[METHODOLOGY]** The integration between DevSecOps and STPA is evaluated through a case study involving software deployed across 22 Primary Health Care Units and one hospital within a single municipality of the Brazilian SUS. LGPD mandates are used to derive system constraints, while DevSecOps pipelines are modeled using STPA to identify Unsafe Control Actions (UCAs) and causal scenarios. **[RESULTS & CONCLUSION]** The analysis integrating DevSecOps and STPA identified [X] UCAs and [Y] loss scenarios associated with activities such as configuration management, vulnerability verification, and deployment approval. The results suggest that STPA can support the identification of systemic socio-technical flaws affecting privacy, security, and safety in DevSecOps pipelines operating under LGPD.

Keywords: DevSecOps; System-Theoretic Process Analysis (STPA); General Data Protection Law (LGPD) ; Healthcare Software

1. INTRODUCTION

Information systems deployed in the healthcare sector are inherently complex and must comply with rigorous regulatory frameworks. In Brazil, the General Data Protection Law (LGPD) [2] establishes mandates for processing personal data, including sensitive health data, with implications for privacy, security, transparency, and data subject rights.

In healthcare software environments, DevSecOps pipelines are increasingly used to automate software development, verification, testing, delivery, and deployment activities. These pipelines commonly incorporate automated mechanisms such as Static Application Security Testing (SAST), Software Composition Analysis (SCA), Infrastructure as Code (IaC) verification, and deployment approval gates.

However, despite automation, DevSecOps pipelines remain socio-technical systems whose behaviour depends on interactions between human operators, organizational processes, and automated tools. As a result, inadequate controls, misconfigurations, missing feedback, or unsafe approvals may still allow vulnerable or non-compliant software to reach production environments.

To analyze these interactions, this project adopts the System-Theoretic Process Analysis (STPA) technique. STPA approaches safety, security, and privacy as control problems, emphasizing how unsafe control actions and feedback mechanisms may contribute to unacceptable losses in complex systems.

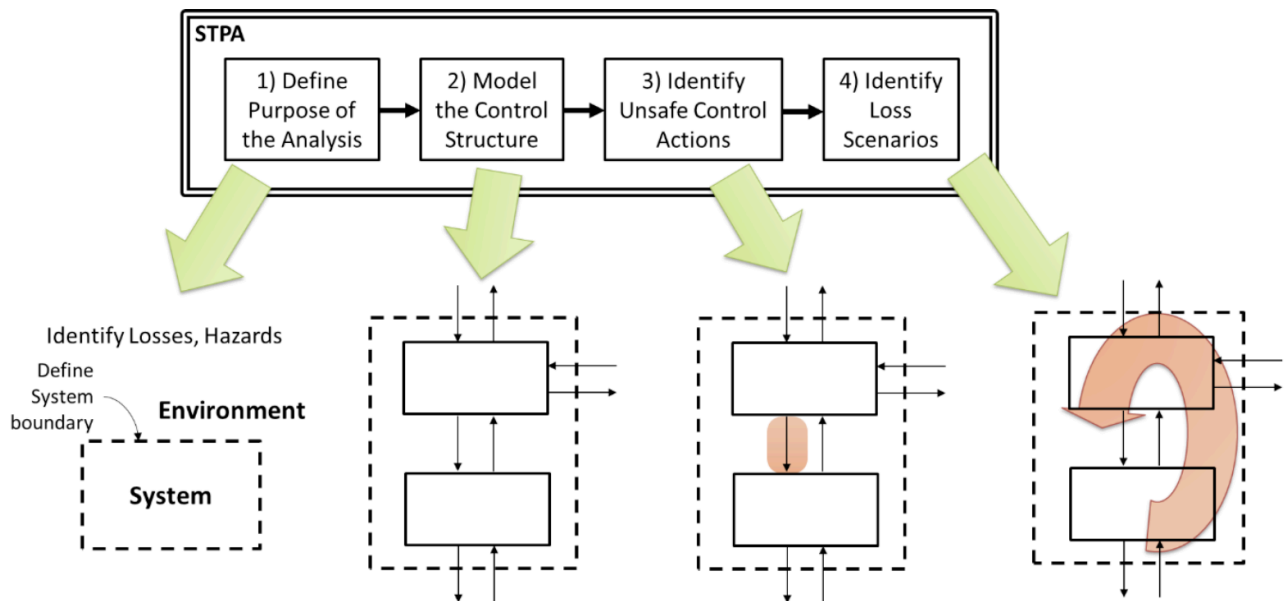
In this work, students will analyze a DevSecOps pipeline as a socio-technical control structure and investigate how inadequate controls and unsafe interactions within software development, delivery, and deployment processes may contribute to privacy, security, and safety violations, ultimately resulting in a LGPD non-compliance loss.

2. BACKGROUND

To explore the feasibility of integrating DevSecOps and STPA, this project adopts a case study involving SisAPEC (Sistema de Aplicação do Processo de Enfermagem no Cuidado), a healthcare software platform currently deployed across 22 Primary Health Care Units and one hospital in a small municipality in Brazil. SisAPEC supports nurses during activities related to the Nursing Process and incorporates Artificial Intelligence techniques to assist professionals during clinical documentation and decision-support activities.

From the STPA perspective, DevSecOps pipelines can be analyzed as socio-technical control systems composed of controllers, feedback mechanisms, automated verification tools, human operators, and deployment processes. In this context, the objective of the analysis is to identify unsafe control actions, inadequate constraints, and loss scenarios capable of contributing to privacy, security, and safety violations throughout the software lifecycle.

3. Partial STPA Analysis Provided to Students



3.1 Introduction and STPA Step 1

A partial STPA analysis will be provided as the starting point for this semester project. Students must study the provided material and continue the analysis according to the instructions presented throughout this document.

The analysis provided to students include excerpts of the 4 STPA Steps:

- Step 1: system description; stakeholders; losses; hazards; system constraints;
- Step 2: control structure diagrams; control actions;
- Step 3: partial unsafe control actions (UCAs); controller level constraints
- Step 4: partial loss scenarios (causal scenarios).

Students are expected to extend and refine the analysis using the concepts discussed during the course, particularly those associated with STPA Step 3 and the new Step 4 of STPA discussed by John Thomas (See *task 1-* in the beginning of this document)

3.2 System Purpose and Goals

SisAPEC is a socio-technical healthcare system that encompasses an AI-enabled healthcare platform, the supporting DevSecOps pipeline, and the organizational processes and stakeholders involved in its operation and evolution. Its high-level goals encompass both the operational efficiency of the Nursing Process, supported by LLM-based agents, and the privacy, security, and compliance requirements established by LGPD. These goals address the needs of multiple stakeholders — including healthcare professionals, patients, system administrators, and the DevSecOps team — while supporting the legal roles and responsibilities defined by the legislation.

Table 1 presents the main stakeholders involved in the SisAPEC ecosystem. These stakeholders encompass both healthcare actors and organizational entities that influence, operate, regulate, or are affected by the system.

Patients act as data subjects and beneficiaries of healthcare services, while nurses constitute the primary users of SisAPEC during the execution of the Nursing Process. Healthcare and SUS managers are responsible for operational and governance activities, respectively. From a data protection perspective, the Data Controller, the Data Protection Officer (DPO), and the Brazilian National Data Protection Authority (ANPD) play key roles in ensuring compliance with the General Data Protection Law (LGPD). Finally, the DevSecOps team is responsible for the development, deployment, operation, and maintenance of the platform throughout its lifecycle.

Table 1. Stakeholder Catalog

Stakeholder	Description
Patients	Data subjects receiving healthcare services.
Nurses	Primary users of SisAPEC during the Nursing Process.
Healthcare Professionals	Authorized healthcare personnel involved in patient care and clinical decision-making activities supported by SisAPEC.
Healthcare Managers	Personnel responsible for healthcare operations and oversight.
SUS Managers	Authorities responsible for healthcare system governance.
Data Controller	Organization responsible for processing decisions under LGPD.
DPO	Data Protection Officer.
ANPD	Brazilian Data Protection Authority.
DevSecOps Team	Personnel responsible for development, deployment, operation, and maintenance of the SisAPEC platform.
System Administrators	Personnel responsible for configuring, managing, monitoring, and maintaining the technical infrastructure supporting SisAPEC.
Auditors	Internal or external personnel responsible for assessing compliance, accountability, traceability, and adherence to regulatory requirements.
Healthcare Institutions	Healthcare organizations responsible for providing services and operating SisAPEC within their facilities.
Community Representatives	Individuals or groups representing the interests, needs, and perspectives of patients and local communities regarding healthcare services and digital technologies.

Table 2 summarizes the SisAPEC goals from the perspective of the stakeholders identified in Table 1. Data Subjects refer to individuals whose personal data are processed by SisAPEC. Data processing activities are governed by the Data Controller, which determines the purposes and means of processing in accordance with LGPD mandates. Healthcare professionals, system

administrators, and DevSecOps personnel may perform data processing activities under the authority of the Data Controller.

The system must also support the role of the Data Protection Officer (DPO), who serves as a communication channel between Data Subjects, the Data Controller, and the National Data Protection Authority (ANPD), the Brazilian authority responsible for overseeing and enforcing LGPD compliance.

Table 2. SisAPEC Goals and Associated Stakeholders

#ID	System goals	Key Stakeholders
SG-1	Provide AI-assisted support for the Nursing Process to enhance clinical decision-making, improve quality of care, and reduce administrative burden on healthcare professionals.	- Nurses - Patients (Data Subjects) - Healthcare Managers
SG-2	Support the identification of clinical risks and the recommendation of evidence-based interventions through Artificial Intelligence capabilities.	- Nurses - Patients - Healthcare Managers - DevSecOps Team
SG-3	Ensure the Confidentiality, Integrity, and Availability (CIA) of personal data and support compliance with LGPD principles and obligations throughout the software lifecycle.	- Patients (Data Subjects) - Data Controller - Data Protection Officer (DPO) - ANPD - Healthcare Professionals - DevSecOps Team - System Administrators
SG-4	Maintain accurate, complete, and traceable clinical documentation to support patient care, accountability, and healthcare decision-making.	- Nurses - Patients (Data Subjects) - Healthcare Managers - Auditors - Healthcare Institutions
SG-5	Ensure interoperability and secure information exchange with relevant SUS information systems.	- Healthcare Professionals - Patients (Data Subjects) - SUS Managers
SG-6	Maintain continuous system availability and reliable software updates across distributed healthcare units without disrupting healthcare services.	- Healthcare Professionals - Patients - SUS Managers - DevSecOps Team
SG-7	Provide an inclusive, accessible, and user-centered digital platform that supports equitable access to healthcare technologies.	- Patients (Data Subjects) - Nurses - Community Representatives
SG-8	Support active stakeholder participation in the evolution of the platform to address healthcare needs and strengthen digital sovereignty within the SUS ecosystem.	- Patients (Data Subjects) - Nurses - Community Representatives - SUS Managers
SG-9	Ensure trustworthy AI-assisted healthcare services by preventing unsafe, insecure, privacy-violating, or non-compliant system behavior.	- Patients (Data Subjects) - Nurses - Data Controller - DPO - DevSecOps Team

		- Healthcare Managers
--	--	-----------------------

In this work, LGPD mandates are treated not merely as compliance checkpoints, but as system-level constraints that must be continuously enforced throughout development and operation. By applying STPA, legal principles such as purpose limitation, data security, and accountability are translated into enforceable control constraints within the DevSecOps pipeline, directly shaping safety, privacy, and security control actions and feedback mechanisms.

This approach is expected to enable the translation of abstract regulatory obligations into losses to be avoided, concrete control actions, feedback mechanisms, and verification activities, thereby allowing safety, privacy, and security to be analyzed as emergent system properties rather than static attributes of an individual software artifact.

Consequently, losses, hazards, safety constraints, and causal scenarios identified during STPA may be traced to corresponding LGPD principles, obligations, and regulatory mandates.

3.3 Losses

Table 3. Unacceptable losses

#ID	Loss
L-1	Unauthorized disclosure of sensitive personal data.
L-2	Legal penalties, sanctions, or regulatory actions due to non-compliance with LGPD.
L-3	Damage to institutional reputation and loss of public trust.
L-4	Loss of the ability to support the Nursing Process due to prolonged system unavailability.
L-5	Harm to patients resulting from inadequate healthcare decisions, recommendations, or interventions.

3.4 System Level Hazards

Table 4. System-level hazards and traceability to losses

#ID	System-level hazards	Losses
H-1	SisAPEC personal data are accessible by unauthorized parties within or through SisAPEC.	[L-1, L-2, L-3]
H-2	Integrity of SisAPEC software services or system behavior is compromised.	[L-1, L-2, L-3, L-4]
H-3	SisAPEC processes sensitive personal data without consent or for purposes inconsistent with those authorized or legally permitted.	[L-2, L-3]
H-4	SisAPEC executes critical system actions and data access without generating or preserving audit trails.	[L-2, L-3]
H-5	SisAPEC is unable to provide required services during healthcare operations.	[L-4, L5]
H-6	SisAPEC provides incorrect or misleading AI-assisted recommendations to healthcare professionals.	[L-5]
H-7	SisAPEC maintains inaccurate, incomplete, or corrupted patient records.	[L-5]

H-8	SisAPEC exchanges inaccurate, incomplete, unauthorized, or inconsistent information with external healthcare systems.	[L-1, L-2, L-3, L-4, L-5]
-----	---	---------------------------

Table 5. System-level constraints and traceability to hazards

#ID	System-level constraints	Hazards
SC-1	Sensitive personal data must be accessible only to authorized entities	[H-1]
SC-2	Integrity of SisAPEC software services and system behavior must be maintained throughout operation and evolution.	[H-2]
SC-3	Sensitive personal data must be processed only for authorized and legally permitted purposes.	[H-3]
SC-4	Critical system actions and data access must be traceable through reliable and tamper-resistant audit records.	[H-4]
SC-5	SisAPEC must provide required services during healthcare operations.	[H-5]
SC-6	AI-assisted recommendations must be clinically appropriate, accurate, and supported by available patient information.	[H-6]
SC-7	SisAPEC and the DevSecOps pipeline must enforce data validation and integrity controls to ensure that patient records remain accurate, complete, and uncorrupted throughout their lifecycle.	[H-7]
SC-8	SisAPEC must remain available when required during patient care activities.	[H-8]

3.5 STPA Step 2 - Model the Control Structure

Figure 2 presents the high-level socio-technical control structure of SisAPEC, depicting the hierarchical control relationships and feedback loops that span regulatory, organizational, and technical levels.

The figure is organized into two complementary perspectives: the left side represents System Development, capturing the governance and management relationships involved in the conception, development, and evolution of the system, while the right side represents System Operation, depicting the governance, oversight, and operational relationships associated with the deployment and use of SisAPEC within the healthcare environment.

Together, these perspectives include actors and processes involved in governance, development, deployment, operation, and regulatory oversight, extending from government institutions and regulatory authorities to the operational software environment. As such, the figure provides a system-wide view of the socio-technical control structure within which SisAPEC operates.

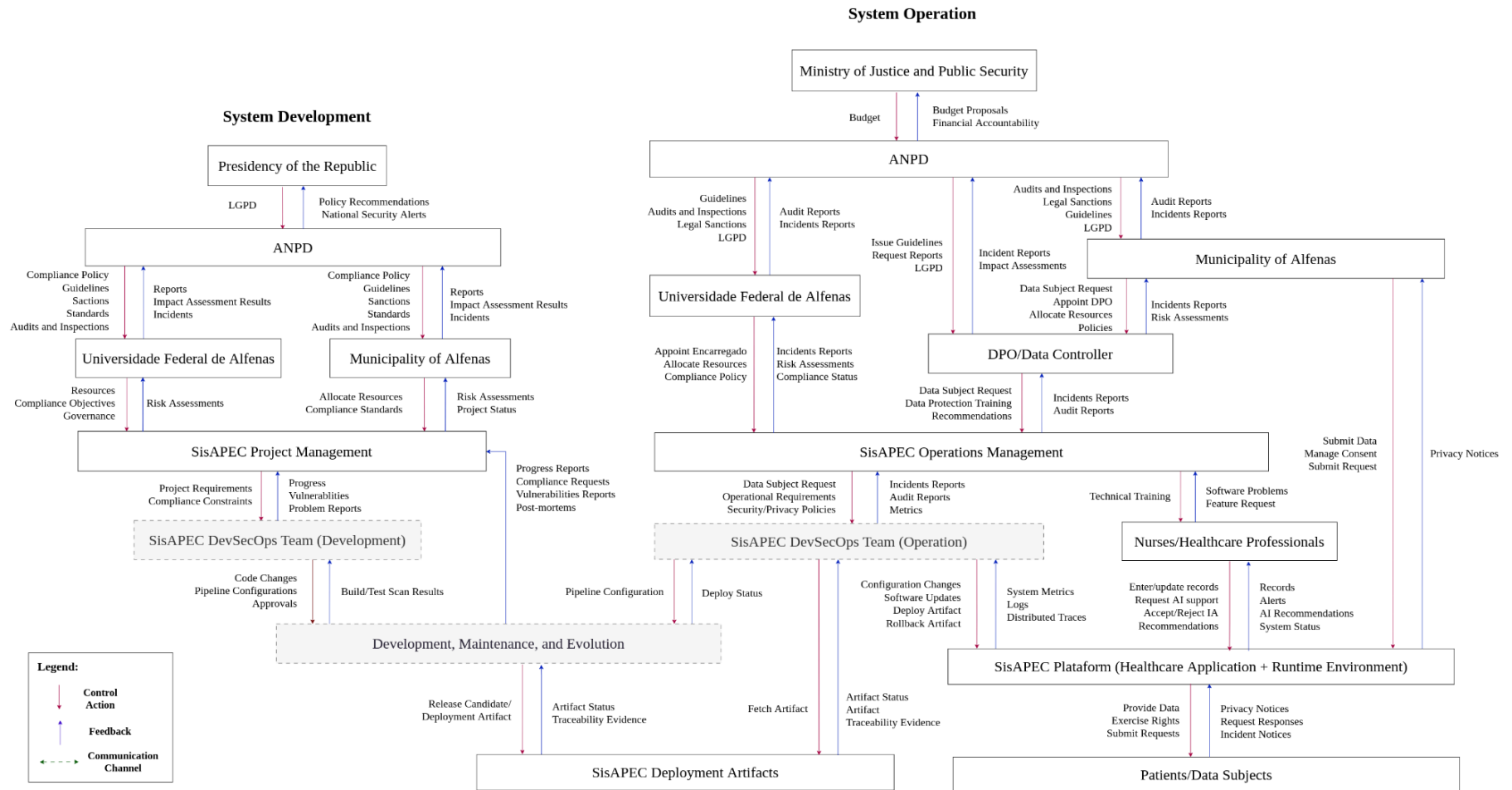


Figure 2. High-Level Socio-Technical Control Structure of SisAPEC, Including System Development and System Operation Perspectives (adapted from Leveson [11]).

Figure 3 presents a refined view of the Development, Maintenance, and Evolution component introduced in Figure 1, expanding the SisAPEC DevSecOps Team and its associated control relationships. The refined control structure focuses on the intersection between development and operations, where software changes are created, validated, deployed, and monitored. Although additional roles and processes exist within the DevSecOps environment, only those relevant to the scope of the analysis are represented.

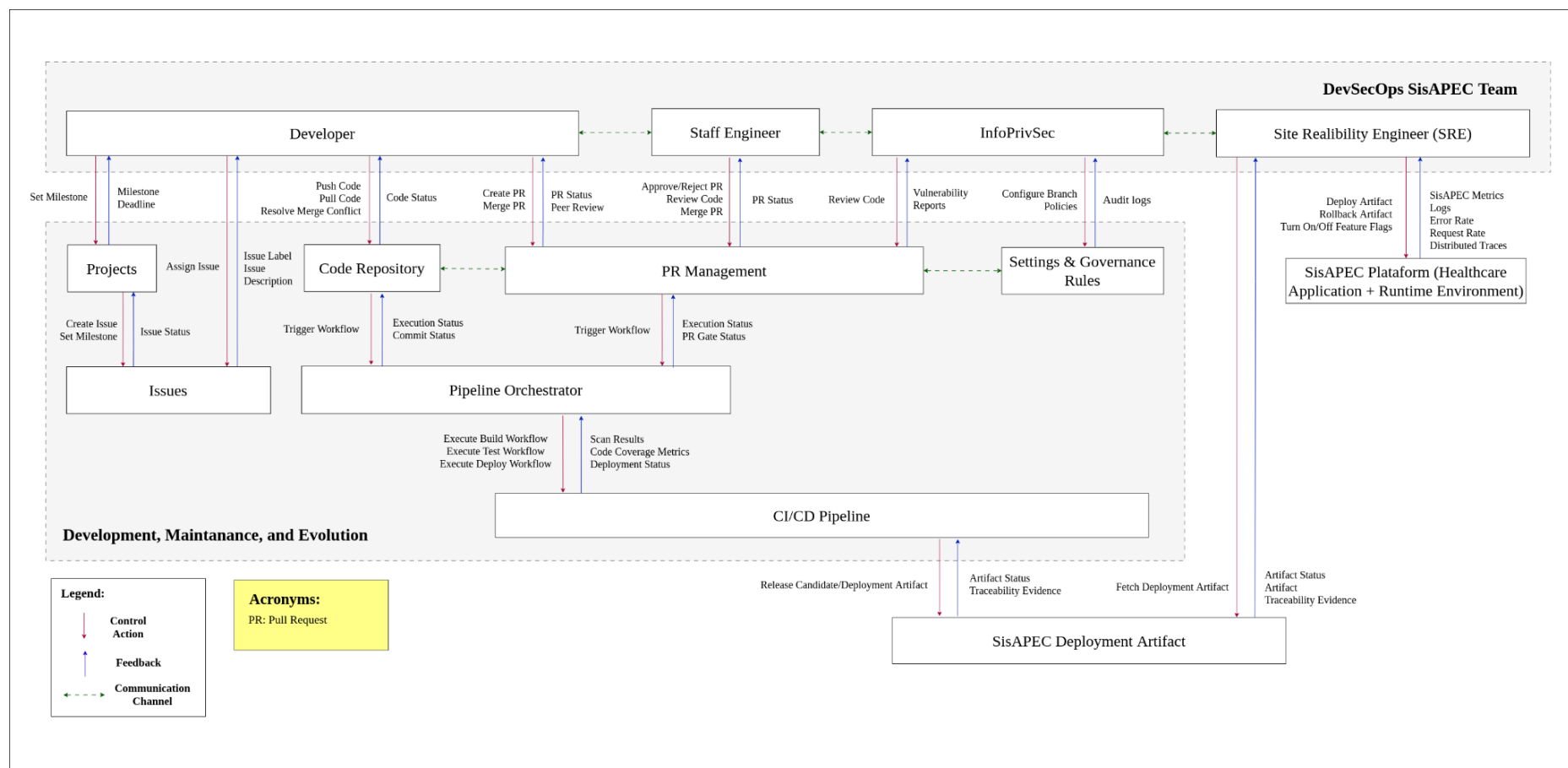


Figure 3. Refined Control Structure of the SisAPEC DevSecOps Team and the Development, Maintenance, and Evolution Component

3.6 STPA Step 3 - Unsafe Control Actions & Controller Level Constraints

Table 6. Example list of unsafe control actions (UCAs)

Controller: Developer		Control Action: Merge PR	
Not providing causes hazard	Providing causes hazard	Too early, too late, out of order	Stopped too soon, applied too long
UCA-5.1: Developer DOES NOT PROVIDE merge PR when peers approve a review, the pipeline verification passes, and the task addresses privacy or security. [H-1, H-2, H-3, H-4]	UCA-5.2: Developer PROVIDES merge PR when the code presents a conflict. [H-2, H-7, H-8] UCA-5.3: Developer PROVIDES merge PR when peers reject a review or lack a decision. [H-1, H-2, H-6, H-7, H-8] UCA-5.4: Developer PROVIDES merge PR when the pipeline verification fails. [H-2, H-5, H-7, H-8]	UCA-5.5: Developer PROVIDES merge PR AFTER a deadline when peers approve the PR, the pipeline verification passes, and a task addresses privacy or security. [H-1, H-2, H-3, H-4]	N/A

Table 7. Example list of Controller level constraints

#ID	Controller level Constraint	UCA
CLC-5.1	Developer MUST PROVIDE merge PR when peers approve a review, the pipeline verification passes, and the task addresses privacy or security.	UCA-5.1
CLC-5.2	Developer MUST NOT PROVIDE merge PR when the code presents a conflict.	UCA-5.2
CLC-5.3	Developer MUST NOT PROVIDE merge PR when peers reject a review or lack a decision.	UCA-5.3
CLC-5.4	Developer MUST NOT PROVIDE merge PR when the pipeline verification fails.	UCA-5.4
CLC-5.5	Developer MUST NOT PROVIDE merge PR AFTER a deadline when peers approve the PR, the pipeline verification passes, and a task addresses privacy or security.	UCA-5.5

3.7 STPA Step 4 - Loss Scenarios (set of causal factors)

Table 8. Example of Representative Causal Scenario for UCA-5.1

Related UCA	UCA-5.1: Developer DOES NOT PROVIDE merge PR when peers approve a review, the pipeline verification passes, and the task addresses privacy or security. [H-1, H-2, H-3, H-4]
Controllers Involved	- Developer - Code Repository - Projects - Issues

Scenario Archetype	Class 1 - Unsafe Controller Behavior
High-Level Scenario	Peer approval and pipeline success feedback was adequate but not providing the merge PR was unsafe.
High-Level Solutions	Developer must immediately execute the merge PR as soon as both valid peer approval and successful pipeline feedback are verified
Refined Scenario	A critical vulnerability affecting patient data boundaries exists within the SisAPEC production system. A corresponding pull request containing the required security or privacy fix is created, reviewed by peers, and successfully passes all automated CI/CD pipeline checks. The repository dashboard correctly indicates that the pull request is approved and ready to be merged. However, the development team is currently under immense pressure to deliver a highly anticipated feature set for hospital stakeholders. Despite the immediate availability of a validated fix, the Developer decides to delay the merge. Due to a flawed risk assessment, the developer misjudges the priority, choosing to delay the critical hotfix to avoid potential deployment instabilities during a high-stakes feature release. Because the system lacks clear visual indicators differentiating an urgent fix from a standard task, and management does not actively monitor the queue for pending security merges, the developer prioritizes the feature work. As a result, the production environment continues to operate with the unresolved defect, leaving sensitive personal data exposed and creating a dangerous window where severe security breaches.
Causal Factors	- Flawed Mental Model - Missing Feedback - Inadequate Oversight
Refined Solutions	Enforce mandatory labeling for any PR addressing privacy or security vulnerabilities. The repository dashboard must display these PRs with high-visibility, distinct visual indicators to prevent them from being treated as standard feature work

3.8 Derived Requirements

Table 9. Example list of Derived requirements

#ID	Derived requirement
DR-1	The DevSecOps pipeline shall prioritize approved privacy and security fixes.
DR-2	Repository interfaces shall provide explicit indicators of remediation urgency.
DR-3	Governance processes shall periodically review pending security-related merges.

REFERENCES

- [1] N. G. Leveson and J. P. Thomas, STPA Handbook, in MA, Cambridge, 2018.
- [2] Brasil. Lei nº 13.709, de 14 de agosto de 2018 (Lei Geral de Proteção de Dados Pessoais – LGPD). Presidência da República, Casa Civil, 2018.